POST-QUANTUM CRYPTOGRAPHY (PQC) SECURE-CODE REVIEWER

An Agentic DevSecOps Framework for Automated Cryptographic Migration (FIPS 203 & FIPS 204)

Domain: Computer Network Security / Applied Crypto
Focus: Quantum-Resilient Code Review (Track 1)
Repo: `natasyafrzan-hub/Quantum-Safe-Secure-Code-Reviewer`

AGENTIC AI ARCHITECTURE | **NIST FIPS 203 (ML-KEM)** | **NIST FIPS 204 (ML-DSA)** | **ZERO-TRUST HITL GATE** | **TAMPER-EVIDENT SHA-256 AUDIT** | **DEVSECOPS CLI & CI/CD**

1. Problem Statement & Threat Model

Nation-state adversaries are actively executing **"Harvest Now, Decrypt Later" (HNDL)** attacks—capturing encrypted enterprise traffic today to decrypt retroactively once Cryptographically Relevant Quantum Computers (CRQCs) emerge.

- **Shor's Algorithm:** Breaks integer factorisation and discrete logarithms in polynomial time, completely compromising **RSA, DSA, ECDSA, DH, and ECDH**.
- **Grover's Algorithm:** Halves symmetric security (AES-128 drops to 64 bits; AES-256 retains 128-bit quantum security).
- **Enterprise Bottleneck:** Legacy codebases contain thousands of hidden cryptographic call sites. Manual auditing is slow, error-prone, and lacks provable audit trails.

2. Research Objectives & Innovation

Develops an autonomous yet strictly governed **AI Security Agent** to automate code auditing and PQC migration with zero-trust safety:

- **Dual-Engine Static Analysis:** AST parsing (Python) and syntax regex (Java) identify vulnerable primitives deterministically with line-level confidence scoring.
- **Explainable AI (XAI):** LLM reasoning generates transparent Chain of Thought (CoT) and explicit uncertainty quantification (distinguishing test code from production).
- **Strict Human-in-the-Loop Gate:** Built via LangGraph's stateful `interrupt()`—no autonomous code modifications occur without signed human approval.
- **Tamper-Evident Provenance:** Recursively links every action into a SHA-256 blockchain-style hash chain for SOC 2 and NIST SP 800-53 compliance.

AGENTIC WORKFLOW: 5-NODE LANGGRAPH DIRECTED ACYCLIC GRAPH (DAG)



3. Post-Quantum Migration Matrix (NIST Standards)

Legacy Primitive	Threat	NIST PQC Replacement	FIPS Standard
RSA (Key Exchange)	Shor (Factoring)	**ML-KEM-768** (Kyber)	FIPS 203 (Cat. 3)
ECDH / DH	Shor (DLP / ECDLP)	**ML-KEM-768**	FIPS 203 (Cat. 3)
ECDSA / DSA / EdDSA	Shor (ECDLP)	**ML-DSA-65** (Dilithium)	FIPS 204 (Cat. 3)
AES-128 / DES / 3DES	Grover / Classical	**AES-256-GCM**	NIST SP 800-38D
MD5 / SHA-1	Collisions + Grover	**SHA-3-256 / SHA-512**	FIPS 202

*Supports hybrid migration modes (e.g. `X25519_ML-KEM-768`) for backwards-compatible TLS/PKI transitions.

4. DevSecOps Architecture & Verification

- **Headless CLI (`pqc_agent/cli.py`):** Automated CI/CD execution. Returns exit code 0 on clean code, exit code 1 on policy violation.
- **Shift-Left Pre-Commit Gate (`.pre-commit-config.yaml`):** Blocks developers from committing deprecated crypto into Git locally.
- **CI/CD Pipelines (`.github/workflows/`):** Multi-version matrix (Python 3.11/3.12), Bandit SAST, pip-audit SCA, and PR audit artifact generation.
- **Production Containerization:** Hardened multi-stage `Dockerfile` with unprivileged user (`UID 10001`), resource quotas, and healthcheck.
- **Verification:** 100% test pass rate across AST detection, patch generation, LangGraph state machine resume, and SHA-256 chain validation.